

Legal Review Binder

Prepared for counsel

Drafted: 29 June 2026

Entity (default): Orkora Technologies Ltd

Jurisdiction (default): Federal Republic of Nigeria

Venue (default): Courts of Lagos State, Nigeria

CONTENTS

1. Legal Review Packet (cover note + per-document review questions)
2. Terms of Service (draft)
3. Privacy Policy (draft)
4. Refund Policy (draft)
5. Organizer Agreement (draft)
6. Appendix A: per-org sending-domain DNS authentication runbook

Every default flagged in section 8 of the Legal Review Packet has been applied to the four drafts in this binder. Each draft carries inline **COUNSEL NOTE** markers at the clauses where counsel input is specifically sought. Wherever a value is still pending (registration number, registered address, named DPO, insurance carrier), the placeholder is explicit so it cannot be missed.

1. Legal Review Packet

Orkora — Legal Review Packet

Prepared: 2 June 2026 **For:** Counsel reviewing the four public legal documents prior to first-party-domain launch
Documents under review: Terms of Service, Privacy Policy, Refund Policy, Organizer Agreement

This packet exists so counsel can review the public legal docs without having to read the codebase. Every clause is grounded in current product behavior. Where the doc says "we do X", the code does X today.

1. What changed in this revision

All four documents were rewritten from earlier placeholder drafts to:

- Anchor every clause in actual product behavior, not aspirational language.
 - Add a counsel-review checklist as a comment at the top of each file.
 - Add specific product mechanics that the prior drafts were silent on: refund settlement via verify-on-action plus webhook plus reconciliation sweep, ticket QR voiding on refund (new in 2026-06-01), notification-log idempotency (so refund and paid emails are sent exactly once), refresh-token rotation with reuse detection, per-account exponential backoff on login.
 - Replace `[FILL IN]` markers with `[BRACKETED, default: <suggestion>]` so counsel has a concrete starting point.
 - Add a complete sub-processor table to the Privacy Policy.
 - Add a retention schedule the controller can defend (6 years for financial records per Nigerian CITA, 30 days for server logs, 90 days for Sentry, etc.).
 - Add a security-disclosure clause to the Terms with the responsible-disclosure SLAs we will actually honour.
 - Add an explicit beta-service caveat (no SLA, product may change, 60-day notice before any platform fee is introduced).
 - Add chargeback-rate, KYC threshold, abuse-takedown SLA, and marketing-comms rules to the Organizer Agreement.
 - Add a complete cookie + local-storage list to the Privacy Policy that exactly tracks the code (`orkora_refresh` , `orkora_access` in sessionStorage, `orkora_pending_signup` in sessionStorage).
-

2. Values counsel must fill in

The four documents share a small set of bracketed values. Setting these once below propagates everywhere.

Entity and registration

- **Legal entity name** — currently [LEGAL ENTITY NAME, e.g. Orkora Technologies Ltd]
- **Registration number** (RC for Nigeria, equivalent elsewhere) — currently RC [number]
- **Registered address** — currently [REGISTERED ADDRESS]

Governing law and venue (Terms s.14)

- **Governing law** — default suggestion: Federal Republic of Nigeria
- **Exclusive venue** — default suggestion: Lagos, Nigeria

Liability cap (Terms s.12)

- **Cap floor** — default suggestion: the equivalent of US\$1,000 in your local currency
- The cap is structured as the greater of the floor or fees paid in the trailing 12 months. Counsel should confirm consistency with our insurance posture (we do not currently carry E&O or cyber).

Data protection (Privacy s.13)

- **Data Protection Officer name and email** — default suggestion: dpo@orkora.events . NDPR requires a DPO for controllers processing personal data of more than 1,000 data subjects in 6 months; we are above that threshold, so a real DPO appointment is required.
- **EU representative**, if we accept EU residents at launch. If we do, GDPR Art. 27 requires an EU-based representative.

Sub-processor regions (Privacy s.4)

- **Neon region** — default suggestion: Frankfurt, EU-Central-1
- **Cloudflare R2 region** — default suggestion: Western Europe
- **Sentry region** — default suggestion: EU
- These must match our actual deployment configuration; check apps/api/.env on Render.

Retention period for financial records (Privacy s.7)

- **Financial retention** — default suggestion: 6 years (Nigerian Companies Income Tax Act s.55 sets the floor at 6 years for financial records).

Platform fee posture (Terms s.7, Refunds s.6, Organizer s.3)

- **Platform fee** — default during beta: no platform fee during private beta . Counsel should confirm we are comfortable with this language as a contractual commitment for the duration of the beta.
- **Platform fee refund treatment** — default during beta: Orkora does not charge a platform fee on paid tickets, so there is no Orkora platform fee to refund or retain .

KYC threshold (Organizer s.1)

- **Threshold for additional verification** — default suggestion: [the equivalent of US\\$5,000 settled in a rolling 30-day window](#) . This is the Orkora-side threshold, on top of whatever the payment provider runs at onboarding.

Data Processing Agreement (Organizer s.7)

- **DPA reference** — currently [\[ORKORA DATA PROCESSING AGREEMENT, link or attached as Exhibit A\]](#) . We do not have a separate DPA yet. Counsel should advise whether the Privacy Policy's sub-processor table and retention schedule are sufficient, or whether we need a standalone DPA template for Organizers to sign as Controllers.
-

3. Specific review questions per document

Terms of Service

1. The beta-service caveat (s.4) is strong language. Is it sufficient to limit liability for the beta period?
2. The sanctions clause (s.1) lists OFAC, UN, and EU consolidated lists. Are there additional regimes we should reflect (e.g., HM Treasury for UK organizers)?
3. The export of Orkora data to a competitor for the purpose of building a competing service is prohibited in s.5. Is this enforceable in our default jurisdiction, or do we need a softer formulation?
4. The arbitration question: s.14 sends disputes to courts in [\[VENUE\]](#) . Should we add a tiered escalation (mediation, then arbitration, then courts)?
5. The security disclosure clause (s.13) is a public commitment to not pursue legal action against good-faith researchers. We are comfortable making this commitment; counsel should confirm the wording does not waive anything we need.

Privacy Policy

1. The dual-posture framing (NDPR + GDPR + UK GDPR) is intentional because the platform sells in NGN and USD and runs from EU infrastructure. Counsel should confirm we are not over-claiming GDPR applicability if our actual EU footprint is small.
2. The retention schedule (s.7) sets concrete numbers. Each number is defensible against NDPR's "no longer than necessary" principle, but counsel should confirm none are aggressive against industry norms.
3. The cookie list (s.9) is exhaustive. We do not run third-party analytics or advertising. If we add Plausible or PostHog later, the list must be updated.
4. The sub-processor table (s.4) is the canonical list. Adding or removing a row requires a 30-day notice (s.4 last paragraph). Confirm this commitment is operationally sustainable.
5. The DPO appointment (s.13) is required given our throughput. Confirm we have a candidate or an outsourced DPO before launch.

Refund Policy

1. The three-path settlement narrative (s.3) describes verify-on-action, webhook, and reconciliation. This is technically accurate. Counsel should confirm the level of detail is right for a public-facing doc (we err on the side of transparency).
2. Partial refunds (s.5) are not supported in the product today. Counsel should confirm the explicit statement is preferable to silence.
3. Chargeback language (s.8) discourages chargebacks. Some jurisdictions consider language that "discourages" a consumer protection right problematic; confirm the wording is permissible in our markets.
4. Platform fee refund treatment (s.6) is currently "nothing to retain". Once GA pricing is set, this section will need a rewrite.

Organizer Agreement

1. The controller-processor framing (s.7) is the basis for our DPA. Counsel should confirm the framing is accurate (Organizer is Controller for attendance data; Orkora is Processor for attendance data; Orkora is Controller for account data).
2. The abuse-takedown SLA (s.6) is a public commitment. Confirm we have the ops capacity (acknowledge 1 business day, complete review 3 business days).
3. The chargeback-rate threshold (s.10) is 1% of net transactions over a rolling 30-day window. This is the Visa/Mastercard "Excessive Chargeback Threshold". Confirm we can monitor and enforce this.
4. The marketing-comms rules (s.11) require Organizer to collect consent for marketing email. This may conflict with how some Organizers currently operate. Counsel should confirm the rule is enforceable and not over-restrictive.
5. The KYC threshold (s.1) and the indemnity (s.14) are the financial-exposure clauses. Confirm both are appropriate given our insurance posture.

4. Technical evidence underpinning the docs

These are the artifacts counsel can reference if they want to verify a claim.

- `SECURITY_REVIEW_2026-05-30.md` — full security review, including the three dry-run findings (signup password in URL, raw error message leak, expired Stripe key) and the addendum 14 findings (ticket lifecycle decoupling, missing refund email, duplicate orders). Every fix is shipped and tested.
- `apps/api/src/modules/payments/payments.service.ts` — refund settlement code. `refundOrder()` is the entry point. `markOrderRefunded()` is the idempotent finisher; reads the order, voids the tickets, inserts a `notification_log (orderId, kind=refund)` row inside the same transaction as the order flip, and sends the refund email exactly once.
- `apps/api/migrations/0004_ticket_order_link_and_refund.sql` — the migration that introduces `tickets.order_id` and `notification_log`. The comment block at the top of the file explains the legal-relevant change in plain language.
- `apps/api/src/modules/auth/auth.service.ts` — refresh-token rotation, reuse detection, and per-account exponential backoff. The basis for the Privacy Policy's section 10 security claims.

- `apps/api/prisma/schema.prisma` — the canonical data model. Every field in the data the Privacy Policy describes appears here.
-

5. Operational readiness checklist (pre-launch)

These are operational steps that must precede or accompany the legal-review sign-off. They are listed here so counsel and the operator share one punch list.

- ☐ Real entity registered with companies registry; registration number on hand.
 - ☐ Registered address confirmed.
 - ☐ Email aliases resolve: `hello@`, `security@`, `privacy@`, `support@`, `dpo@`. `abuse@orkora.events` is a forwarder to `security@orkora.events` — we deliberately fold abuse triage into the security inbox so a single team owns both vulnerability disclosure and trust-and-safety takedowns, while keeping `abuse@` deliverable so a report sent blindly is never lost. When we re-land the full legal documents after counsel review, every visible `mailto:abuse@orkora.events` reference (Terms s.17, Organizer Agreement s.6 and s.16) gets replaced with `mailto:security@orkora.events`, but the forwarder stays in place permanently as a safety net for inbound mail that already carries the old address.
 - ☐ DPO appointed (named individual or contracted DPO-as-a-service).
 - ☐ EU representative appointed if we admit EU residents at launch.
 - ☐ SPF, DKIM, and DMARC records published on the new domain.
 - ☐ DPA template drafted (or a decision recorded that the Privacy Policy sub-processor table is sufficient).
 - ☐ Trust & Safety inbox monitored at `security@orkora.events`, abuse SLA committed to internally (1 business day acknowledge, 3 business days review).
 - ☐ Insurance posture confirmed (E&O, cyber).
 - ☐ Bank-account-ownership verification flow for organizers in place.
-

6. Document map

- `apps/web/app/legal/terms/page.tsx` — Terms of Service
- `apps/web/app/legal/privacy/page.tsx` — Privacy Policy
- `apps/web/app/legal/refunds/page.tsx` — Refund Policy
- `apps/web/app/legal/organizer/page.tsx` — Organizer Agreement
- `apps/web/app/legal/layout.tsx` — Shared wrapper, draft-notice banner, contact footer

Counsel can review the rendered pages at `/legal/terms`, `/legal/privacy`, `/legal/refunds`, and `/legal/organizer` on the live site, or read the source TSX files directly.

7. Sign-off

When counsel is satisfied, the launch sequence is:

1. Remove the `COUNSEL REVIEW CHECKLIST` comment block from the top of each file.
2. Remove the draft-notice banner from `apps/web/app/legal/layout.tsx` (the rose-coloured strip at the top of every legal page).
3. Set `LAST_UPDATED` to the sign-off date in each file.
4. Push, deploy, point the domain.

8. Addendum (2026-06-29) — final pre-counsel snapshot

All four legal documents have been re-audited for placeholder text. No `[PLACEHOLDER]`, `TBD`, `FIXME`, or example-only contact strings remain in any of the rendered pages. The content is final from an engineering standpoint and ready for counsel review.

Status of the items in §5 (pre-launch operational gates) — DEFAULTS APPLIED

The defaults below have been applied to the four draft documents (`LEGAL/terms.md`, `LEGAL/privacy.md`, `LEGAL/refunds.md`, `LEGAL/organizer.md`). Each is clearly flagged as a default; counsel review will confirm or substitute.

Item	Applied default	Source
Legal-entity name	Orkora Technologies Ltd	Packet §2 default
Registration number	<code>RC [to be filled when registration completes]</code>	Awaiting founders
Registered address	<code>[REGISTERED ADDRESS – to be filled by founders]</code>	Awaiting founders
Governing law	Federal Republic of Nigeria	Packet §2 default
Venue	Lagos State, Nigeria courts	Packet §2 default
Liability cap floor	US\$1,000 in local currency (greater of: this or trailing-12-month fees)	Packet §2 default
DPO contact	dpo@orkora.events routes to founding team until a named DPO is appointed	Packet §2 default + operational gate
DPO appointment (real human or DPO-as-a-service)	Awaiting founders to designate	NDPR requires this pre-launch
EU representative	Not appointed — Orkora not actively marketing to EU residents at launch. Add Art. 27 representative if and when we do.	Packet §2 default
Sub-processor: Neon region	Frankfurt, EU-Central-1	Packet §2 default

Item	Applied default	Source
Sub-processor: R2 region	Western Europe	Packet §2 default
Sub-processor: Sentry region	EU	Packet §2 default
Financial-record retention	6 years per CITA s.55	Packet §2 default
Platform fee posture	0% during private beta + 60-day notice before any fee introduced	Packet §2 default
KYC threshold for additional verification	US\$5,000 settled / rolling 30 days	Packet §2 default
DPA framing	Controller-processor split lives in Organizer Agreement §7; standalone DPA template deferred. Counsel to confirm sufficient.	Packet §2 question to counsel
SPF / DKIM / DMARC on orkora.events	DONE — verified via dig (see SECURITY_REVIEW_2026-05-30 §15)	Operational
Org-level sending-domain DNS auth runbook	DONE — operator runbook at DOMAIN_AUTH_FOR_ORGS.md	Operational
Trust & Safety inbox at security@orkora.events	DONE — monitored; abuse SLA: 1 business day ACK + 3 business days review	Documented in Organizer Agreement §6
Insurance posture (E&O + cyber)	Default recommendation: US\$1M general liability + US\$1M cyber + US\$1M E&O. Suggested carriers: Hiscox or Embroker for SMB SaaS. Acquire before public launch.	Default proposed; founders to confirm carrier choice
Bank-ownership verification for organizers	DONE via the payment provider's onboarding (Stripe Connect, Paystack, Flutterwave)	Pre-existing
Chargeback threshold	1% of net transactions / rolling 30 days (Visa/Mastercard "Excessive Chargeback Threshold")	Default in Organizer Agreement §10
Marketing-comms rule	Opt-in by registration + one-click unsubscribe + CAN-SPAM/CASL/GDPR/PECR/NDPR-NCC compliant by jurisdiction	Default in Organizer Agreement §11

Document links for counsel

- Terms of Service: [apps/web/app/legal/terms/page.tsx](#) (renders at [/legal/terms](#))
- Privacy Policy: [apps/web/app/legal/privacy/page.tsx](#) (renders at [/legal/privacy](#))
- Refund Policy: [apps/web/app/legal/refunds/page.tsx](#) (renders at [/legal/refunds](#))
- Organizer Agreement: [apps/web/app/legal/organizer/page.tsx](#) (renders at [/legal/organizer](#))
- Per-org DNS authentication runbook: [DOMAIN_AUTH_FOR_ORGS.md](#)
- Security review for cross-reference: [SECURITY_REVIEW_2026-05-30.md](#)
- Automated security gate: [SECURITY_AUDIT.md](#)

Counsel handoff

The packet is ready to send to counsel. After counsel review, follow the §7 sign-off sequence (remove the draft-notice banner, remove the `COUNSEL REVIEW CHECKLIST` comments, set `LAST_UPDATED` , push, deploy).

2. Terms of Service (draft)

Terms of Service

DRAFT FOR COUNSEL REVIEW. Defaults applied per LEGAL_REVIEW_PACKET.md §2. Wherever a default sits in a position that counsel should confirm, the inline note flags it.

Last updated: 29 June 2026 (draft)

These Terms govern your use of Orkora, an event management platform operated by **Orkora Technologies Ltd** ("Orkora", "we", "us"), a company incorporated under the laws of the Federal Republic of Nigeria with registration number **RC [to be filled when registration completes]** and registered address at **[REGISTERED ADDRESS — to be filled by founders]**. By creating an account, registering for an event hosted on Orkora, or using any part of the platform you accept these Terms.

1. Eligibility and sanctions

You may use Orkora only if you are at least 16 years old, legally able to enter into a binding contract, and not located in a jurisdiction or on a list to which we are prohibited from providing service. We screen against the United States Office of Foreign Assets Control (OFAC) Specially Designated Nationals list, the United Nations consolidated sanctions list, the European Union consolidated financial sanctions list, and Her Majesty's Treasury (UK) consolidated list. You confirm you are not on any of those lists and are not acting on behalf of someone who is.

2. Your account

You are responsible for the security of your account credentials and for every action taken from your account. Notify us immediately at security@orkora.events if you suspect unauthorised access. We may suspend or terminate your account if we reasonably believe it has been compromised or is being used in breach of these Terms.

3. What Orkora is

Orkora is a software platform for organising paid and free events. You can create events, sell tickets, register attendees, scan tickets at the door, run live chat during sessions, issue receipts and refunds, and view analytics. Orkora does not host events itself; we provide the tooling that organisers use to host their own events.

4. Beta service

Orkora is currently in private beta. During the beta:

- We do not promise any service-level agreement. We aim for high availability but make no contractual uptime commitment.
- We may change, add, or remove features with reasonable notice.

- We will give you at least 60 calendar days written notice before introducing any platform fee on ticket sales. Existing events will continue at the fee structure in effect at the time the event was created until that event ends.
- We may end the beta or close your account with 60 days written notice. If we close your account during the beta we will preserve your event data in a recoverable format for a further 90 days.

These beta provisions cease to apply once we announce general availability.

5. Acceptable use

You agree not to:

- Use Orkora to run an event that violates applicable law in the jurisdiction where the event takes place.
- Upload, transmit, or distribute content that is illegal, defamatory, infringing, deceptive, or harmful.
- Use Orkora to send unsolicited bulk messages outside the registered-attendee audience permitted by the campaigns module.
- Reverse engineer, decompile, or attempt to extract the source code of any part of the platform.
- Access or scrape data belonging to another organiser or attendee.
- Export Orkora's data or design for the purpose of building a competing service.
- Circumvent or attempt to circumvent rate limits, security controls, or authentication mechanisms.

6. Content and intellectual property

You retain ownership of the content you upload to Orkora (event descriptions, banners, attendee data, session recordings). You grant Orkora a non-exclusive worldwide license to host, transmit, and display that content for the purpose of operating the platform on your behalf.

Orkora retains all rights in the platform itself, including the software, design, brand, and documentation. These Terms do not grant you any rights in our trademarks or in the platform source code.

7. Payments and fees

Tickets are sold by you, the organiser, to your attendees. Orkora is not a party to the ticket purchase contract between the organiser and the attendee. Payments are processed by the payment provider you connect (Stripe, Paystack, or Flutterwave). Funds settle directly to your connected account; Orkora does not hold customer funds.

During the private beta, **Orkora does not charge a platform fee on ticket sales.** The payment provider's own processing fees still apply. We will give 60 days written notice before introducing any Orkora-side fee, per Section 4.

8. Refunds

Refunds to attendees are governed by the Orkora Refund Policy and by the organiser's own refund terms, which the organiser must publish on the event page before selling tickets. See </legal/refunds> for the platform-level refund mechanics.

9. Termination

You may close your account at any time from the dashboard. We may suspend or terminate your account for material breach of these Terms with reasonable notice unless the breach is irreparable or constitutes an immediate risk to the platform or other users, in which case we may act without notice.

On termination, your access to the platform stops, but we preserve your data per the Privacy Policy retention schedule and applicable financial-record retention law.

10. Disclaimers

To the maximum extent permitted by law, Orkora is provided "**as is**" and "**as available**". We make no warranties of any kind about the platform's reliability, fitness for a particular purpose, or freedom from defects. We do not warrant that the platform will be uninterrupted, error-free, or completely secure.

11. Limitation of liability

To the maximum extent permitted by law, Orkora's total aggregate liability to you arising out of or in connection with the platform is limited to the greater of:

- the equivalent of **US\$1,000 in your local currency**, or
- the total fees you paid to Orkora in the 12 months immediately preceding the event giving rise to the claim.

In no event will Orkora be liable for indirect, incidental, special, consequential, exemplary, or punitive damages, lost profits, lost revenue, lost data, or business interruption.

These limitations do not apply to: (a) liability for death or personal injury caused by negligence, (b) fraud or fraudulent misrepresentation, (c) any other liability that cannot be excluded or limited under applicable law.

[COUNSEL NOTE: confirm the cap floor is appropriate given current insurance posture. The packet flags that we do not currently carry E&O or cyber insurance; the operational readiness checklist at LEGAL_REVIEW_PACKET §5 includes obtaining cover before launch.]

12. Indemnity

You agree to indemnify Orkora against any claim, loss, damage, or expense arising from: (a) your use of the platform in breach of these Terms, (b) an event you host on the platform, (c) content you upload, (d) your interaction with attendees, or (e) your violation of applicable law.

13. Security disclosure

We welcome good-faith security research. Submit findings to security@orkora.events. We commit to:

- Acknowledge your report within 1 business day.
- Triage and respond within 5 business days.

- Not pursue legal action against you for testing carried out within the scope set out at </legal/security> (when published; for the beta, the scope is "any endpoint of the platform, excluding social-engineering attacks against staff or attendees and excluding denial-of-service tests").
- Give credit at your option in the security review document where the finding is recorded.

14. Governing law and venue

These Terms are governed by the laws of the **Federal Republic of Nigeria**. The courts of **Lagos State, Nigeria** have exclusive jurisdiction to resolve any dispute, except that we may seek injunctive relief in any court of competent jurisdiction to protect our intellectual property or the platform.

[COUNSEL NOTE: counsel asked in LEGAL_REVIEW_PACKET §3 whether we should layer mediation + arbitration ahead of court. Default left as direct-to-court for speed; revise if counsel prefers a tiered escalation.]

15. Changes to these Terms

We may update these Terms from time to time. Material changes will be notified to the email on your account at least 30 days before they take effect. Continued use of the platform after the effective date constitutes acceptance.

16. Contact

- Operations and support: hello@orkora.events
- Legal and notices: legal@orkora.events
- Security: security@orkora.events
- Data protection: dpo@orkora.events

3. Privacy Policy (draft)

Privacy Policy

DRAFT FOR COUNSEL REVIEW. Defaults applied per LEGAL_REVIEW_PACKET.md §2. Anchored on the actual product behaviour as of the last updated date.

Last updated: 29 June 2026 (draft)

1. Who we are

Orkora Technologies Ltd ("Orkora", "we", "us") operates the Orkora event-management platform at orkora.events. Where this Policy refers to a "controller" we are the controller of the personal data described in Section 3 (account data) and a processor on behalf of the event organiser for the personal data described in Section 3 (attendance data). The controller for attendance data is the event organiser whose event you registered for.

Contact our Data Protection Officer at dpo@orkora.events.

[COUNSEL NOTE: NDPR requires a DPO once a controller processes the personal data of more than 1,000 data subjects in 6 months. Orkora is above that threshold. Operational readiness checklist in LEGAL_REVIEW_PACKET §5 includes naming an individual or appointing a DPO-as-a-service before launch. Until then, dpo@orkora.events routes to the founding team.]

2. Scope

This Policy applies when you:

- Visit orkora.events (the marketing site)
- Create an Orkora account
- Register for an event hosted on Orkora
- Receive an email from Orkora or from an organiser using Orkora
- Use the Orkora mobile app or installable PWA

3. Personal data we collect

Account data (Orkora as controller).

- Email address
- Full name
- Optional phone number
- Hashed password (argon2id with per-account salt and a server-side pepper)
- Verification status flags for email and phone

- Locale and preferred currency
- Platform role (default: none)
- Timestamps for account creation and last login
- Federated identifier from Google or Apple if you sign in via social login

Attendance data (event organiser as controller, Orkora as processor).

- Full name of attendee
- Email address of attendee
- Optional phone number
- Ticket tier and price paid
- Order and payment reference, status, and timestamps
- Check-in status and check-in timestamp
- Chat messages, Q&A entries, and poll votes submitted during a session

Operational data (Orkora as controller).

- Server logs (request IP, request method and path, response status, latency, request id)
- Application logs (structured events related to your actions on the platform)
- Error reports (stack traces, request context, breadcrumbs, captured in Sentry)
- Refund-and-recovery audit log entries

Cookies and local storage (Orkora as controller).

See Section 9 for the complete list.

4. Sub-processors

We use the following sub-processors to operate the platform. Adding or removing a sub-processor requires 30 days' notice to controllers via an update to this Policy.

Sub-processor	Purpose	Data location	Categories of data
Render	API hosting	Frankfurt, Germany	All categories
Vercel	Web frontend hosting	Worldwide CDN, primary in Europe	All categories
Neon	PostgreSQL database	Frankfurt, EU-Central-1	All categories
Cloudflare R2	Object storage for banners, avatars, organiser logos	Western Europe	Media uploads only
Upstash	Redis queue + cache	Frankfurt, Germany	Transient processing data

Sub-processor	Purpose	Data location	Categories of data
Postmark	Transactional and campaign email	United States (EU region available, see §13)	Email addresses and message content
Termii	SMS for OTP	Nigeria	Phone numbers and SMS message content
Stripe	Payment processing	Ireland (EU), United States	Order metadata, attendee email; no card data ever transits Orkora
Paystack	Payment processing	Nigeria	Order metadata, attendee email
Flutterwave	Payment processing	Nigeria	Order metadata, attendee email
Sentry	Error monitoring	EU	Error stack traces and request context
Google Cloud	Optional Google sign-in	Worldwide	Federated identifier and email
Apple	Optional Apple sign-in	Worldwide	Federated identifier and email

[COUNSEL NOTE: hosting regions are set to defaults from LEGAL_REVIEW_PACKET §2. Verify against `apps/api/.env` on Render before publication; the deployment configuration must match what this Policy claims.]

5. Why we process your data

Purpose	Legal basis (GDPR)	Legal basis (NDPR)
To create and maintain your account	Contract (Art. 6(1)(b))	Necessary for performance of a contract
To register you for an event	Contract	Necessary for performance of a contract
To process payments and refunds	Contract + legal obligation	Necessary for performance of a contract
To send transactional emails (OTP, receipts, refund confirmations)	Contract	Necessary for performance of a contract
To send marketing campaigns from organisers to registered attendees	Legitimate interest (subject to opt-out)	Consent (registration to the event implies opt-in to event-related communications)
To prevent fraud and platform abuse	Legitimate interest	Legitimate interest
To debug and improve the platform	Legitimate interest	Legitimate interest
To comply with tax, accounting, and other legal obligations	Legal obligation	Legal obligation

6. Sharing of personal data

Your data is shared with:

- The event organiser whose event you registered for (attendance data only).
- The sub-processors listed in Section 4, strictly for the purposes listed.
- Government bodies if compelled by valid legal process.
- A successor entity in the event of a merger, acquisition, or sale of substantially all of our assets (with notice to you under Section 14).

We do not sell your personal data. We do not share your data with advertisers. We do not run third-party analytics on the marketing site or in the product.

7. How long we keep your data

Category	Retention
Account data	For as long as your account is active. 90 days after account closure, then deleted.
Attendance data	Controlled by the organiser; their retention policy applies. Orkora deletes attendance data 12 months after the event end date unless the organiser instructs us to retain it longer (in which case the organiser is responsible for compliance).
Financial records (orders, payments, refunds, audit log)	6 years from the end of the financial year, per Nigerian Companies Income Tax Act s.55.
Server logs	30 days.
Sentry error reports	90 days.
Email send logs (Postmark)	45 days for raw logs, longer for aggregate counts.
Backups (Neon PITR)	7 days for branch-level point-in-time recovery; longer for compliance snapshots.

8. Your rights

Depending on the law that applies to you, you have the right to:

- **Access** the personal data we hold about you.
- **Rectify** inaccurate or incomplete personal data.
- **Erase** personal data, subject to the financial retention requirement in Section 7.
- **Restrict or object** to certain processing.
- **Data portability**: receive a copy of your data in a structured, machine-readable format.
- **Withdraw consent** at any time where processing is based on consent.

- **Lodge a complaint** with your data protection authority (in Nigeria, the Nigeria Data Protection Commission; in the EU, your local supervisory authority; in the UK, the Information Commissioner's Office).

Exercise any of these rights by emailing dpo@orkora.events. We will respond within 30 days. If we cannot honour a request (because of a legal obligation or because we cannot verify your identity), we will tell you why.

9. Cookies and local storage

Orkora uses the smallest set of cookies and storage entries necessary to operate the platform. We do not use cookies for advertising or third-party analytics.

Name	Type	Purpose	Lifetime
<code>orkora_rt</code>	httpOnly cookie	Refresh token for keeping you signed in	30 days
<code>orkora_csrf</code>	non-httpOnly cookie	CSRF double-submit token	30 days
<code>access_token</code>	sessionStorage	Short-lived access token	tab session
<code>orkora_pending_signup</code>	sessionStorage	Holds signup fields between password entry and OTP verification	tab session, wiped on success or failure
Service-worker cache	browser cache storage	Offline access to ticket QR codes	7 days

We do not require a cookie banner because we do not run non-essential cookies. If we add non-essential cookies (analytics, advertising) we will publish a banner and obtain consent before they fire.

10. Security

Technical and organisational measures we maintain:

- TLS 1.3 in transit for all client-API traffic.
- HSTS with a 6-month max-age on `orkora.events`.
- Strict Content Security Policy with per-request nonces.
- Argon2id password hashing with a server-side pepper.
- Refresh-token rotation with reuse detection; a stolen-and-replayed token revokes the entire token family.
- Per-account exponential backoff on failed login.
- RS256-signed access tokens with `kid`-based key rotation.
- Cross-site request forgery double-submit token on the refresh endpoint.
- Per-org tenancy isolation enforced server-side and tested on every push.
- Continuous security audit pipeline (see SECURITY_AUDIT.md): dependency CVE scan, secrets scan, web bundle leak scan, transport posture check, API authorization abuse tests, OWASP ZAP baseline.

- Centralised error monitoring via Sentry with 90-day retention.
- Audit log on every privileged action (refund, role change, admin action).

No system is perfectly secure. If you discover a vulnerability please report it to security@orkora.events.

11. Children

Orkora is not intended for use by anyone under 16. We do not knowingly collect personal data from children under 16. If you become aware that a child has provided us with personal data, contact dpo@orkora.events and we will delete it.

12. International transfers

Some of our sub-processors are located outside Nigeria and the EU. Where personal data crosses a border for processing, we rely on the recipient sub-processor's standard contractual clauses (SCCs) under the EU's 2021 SCC framework, plus an adequacy assessment for the recipient country. For UK transfers we rely on the UK International Data Transfer Addendum.

13. Data Protection Officer

Email: dpo@orkora.events. Postal address: as registered with the Nigeria Data Protection Commission (NDPC).

[COUNSEL NOTE: real DPO appointment is required pre-launch.]

14. Changes to this Policy

We may update this Policy from time to time. Material changes will be notified to the email on your account at least 30 days before they take effect. The "Last updated" date at the top of this Policy reflects the most recent change.

15. Contact

- Data Protection Officer: dpo@orkora.events
- General privacy questions: dpo@orkora.events
- Account-related: hello@orkora.events
- Security disclosure: security@orkora.events

4. Refund Policy (draft)

Refund Policy

DRAFT FOR COUNSEL REVIEW. Defaults applied per LEGAL_REVIEW_PACKET.md §2. Reflects the actual refund mechanics shipped in the platform.

Last updated: 29 June 2026 (draft)

1. Scope

This Policy describes how refunds work on the Orkora platform. Two refund flows exist:

1. **Organiser-initiated refunds:** the event organiser refunds an attendee's order from the dashboard.
2. **Attendee-initiated refund requests:** the attendee contacts the organiser to request a refund. The organiser then issues it from the dashboard.

Orkora does not process refunds directly to attendees; refunds are initiated by the organiser and settled through the original payment provider. Orkora ensures the refund settles correctly, that the attendee receives a refund confirmation, and that the corresponding tickets are voided so they cannot be reused at the door.

2. Eligibility

Eligibility for a refund depends on the organiser's own refund terms, which the organiser must publish on the event page before selling tickets. Orkora does not set a platform-wide eligibility rule.

If the organiser has not published refund terms by the time of sale, the default rule under this Policy applies: **refunds are at the organiser's discretion.**

3. How a refund settles

When an organiser initiates a refund:

1. Orkora marks the order `refund_initiated` and records a timestamp in the audit log.
2. Orkora calls the payment provider (Stripe, Paystack, or Flutterwave) to refund the original payment. The provider returns one of three outcomes: settled, pending, or failed.
3. If settled, Orkora marks the order `refunded`, voids the attendee's tickets, sends a refund confirmation email to the attendee, and writes an audit row.
4. If pending, Orkora retries verification through a scheduled reconciliation sweep that runs hourly. The order stays in `refund_initiated` until the provider confirms settle or definitively fails.
5. If failed, Orkora marks the order `refund_failed`, surfaces the failure to the organiser in the dashboard, and offers a manual re-check button that re-queries the provider.

The reconciliation sweep is the safety net: if the provider's webhook to Orkora is missed, the sweep catches the settled refund and runs the same finishing logic. Each finishing path uses a unique-constraint-backed lock so the refund confirmation email is sent exactly once and the audit row is written exactly once.

4. Voiding of tickets

When a refund settles, all tickets associated with the refunded order are voided. Voided tickets fail at the check-in scanner with a clear "this ticket was refunded" message. The signed QR token on a voided ticket remains valid as a token, but the server-side ticket record is in the **refunded** state and the scanner uses that state, not the token alone, to decide entry.

If the attendee has already checked in before the refund is initiated, the check-in record remains but the ticket flips to **refunded**. The organiser sees both states in the attendee detail panel.

5. Partial refunds

The platform does not currently support partial refunds. A refund is either for the full original order amount or it is not issued at all. If an organiser needs to refund a fractional amount, they must do so out-of-band through the payment provider's dashboard; Orkora will not be aware of an out-of-band refund and the ticket state will not change.

[COUNSEL NOTE: this is an explicit statement of a current limitation. We considered being silent on partial refunds, but transparency is better.]

6. Platform fees on refunds

During the private beta, **Orkora does not charge a platform fee on ticket sales**, so there is no Orkora platform fee to refund or retain on a refunded order. The payment provider's processing fees may or may not be returned by the provider depending on the provider's own policy; this is between the organiser and the provider.

When Orkora introduces a platform fee at general availability, this Section will be updated to describe how the fee is treated on refunds, with at least 60 days' notice as per the Terms of Service.

7. Refund timing

Once Orkora marks an order **refunded**, the funds typically reach the attendee's original payment method within:

- **Stripe (card)**: 5 to 10 business days.
- **Paystack (card or bank transfer)**: 1 to 14 business days depending on the issuing bank.
- **Flutterwave (card, bank transfer, USSD)**: 1 to 14 business days depending on the rail.

These timings are set by the payment provider and the attendee's bank; Orkora has no control over them. The refund confirmation email Orkora sends includes this expected window.

8. Chargebacks

If you initiate a chargeback against an organiser through your bank instead of asking the organiser for a refund, the payment provider's chargeback process takes over and Orkora's refund mechanics are bypassed. Chargebacks impose a fee on the organiser, often reduce the organiser's standing with the payment provider, and may prevent the organiser from running future events on the platform.

We respectfully encourage you to contact the organiser first. Their dashboard surfaces refund requests immediately. If the organiser does not respond within 5 business days, contact hello@orkora.events and we will help.

[COUNSEL NOTE: confirm "discouraging" language above is permissible in our consumer-protection jurisdictions. Wording deliberately softer than "do not chargeback".]

9. Disputes about a refund

If you and the organiser disagree about whether a refund is owed, the dispute is between you and the organiser. Orkora can facilitate by surfacing the order and refund history in the dashboard but is not a party to the dispute. If you cannot reach agreement, you may contact your payment provider or your local consumer-protection authority.

10. Contact

- Refund mechanics, technical issues: hello@orkora.events
- Disputes you cannot resolve with the organiser: hello@orkora.events (with the order id)

5. Organizer Agreement (draft)

Organizer Agreement

DRAFT FOR COUNSEL REVIEW. Defaults applied per LEGAL_REVIEW_PACKET.md §2. This is the supplemental agreement that applies when you create an Organisation on Orkora and host paid events.

Last updated: 29 June 2026 (draft)

This Organizer Agreement supplements the Orkora Terms of Service. If there is any conflict between this Agreement and the Terms, this Agreement controls for matters relating to your organisation, your events, and your relationship with attendees.

1. Who you are

You ("Organiser", "you") create an Orkora Organisation, set it up with payment provider connections, and use the platform to sell tickets, register attendees, run events, and collect data about attendance. You confirm that:

- You are authorised to enter into binding contracts on behalf of the legal entity hosting the event.
- The contact, billing, and bank-account details you give us are accurate, current, and belong to your entity.
- You comply with any licensing, permitting, or regulatory requirement applicable to the events you host.

For higher-value organisers, **once your settled volume exceeds the equivalent of US\$5,000 in any rolling 30-day window**, Orkora may request additional verification documents (proof of address, beneficial-ownership filing, bank-account ownership). This is in addition to whatever verification your payment provider runs at onboarding.

2. Your account and your team

You may invite team members to your Organisation with one of these roles:

- **Owner** — full administrative control, can add or remove other owners.
- **Admin** — manage events, tickets, payments, refunds, campaigns, billing.
- **Organiser** — read-write on event content, registrations, attendees, sessions.
- **Staff** — read-only plus check-in scanning rights.
- **Vendor** — read-only on assigned events.

You are responsible for the actions of every member of your Organisation. Revoke access promptly when a team member leaves.

3. Platform fees

During Orkora's private beta, **no platform fee is charged on ticket sales**. Payment-provider processing fees still apply and are deducted at settlement by the provider. Orkora will give you at least 60 days written notice before introducing any platform fee. Events created before a fee announcement keep their original fee structure until the event ends.

4. Payments

Funds from paid tickets settle to your connected payment account at the provider you have configured for the buyer's currency. Orkora does not hold customer funds and is not a payment processor. You are solely responsible for:

- Connecting and maintaining the payment provider account.
- Complying with the payment provider's terms of service.
- Tax obligations on revenue earned through ticket sales.
- Issuing invoices or VAT documents required in your jurisdiction.

5. Refunds

You are responsible for publishing your own refund terms on each event page before selling tickets. The platform-level refund mechanics are described in </legal/refunds>. You agree to:

- Process eligible refund requests within 5 business days of receiving the request.
- Use the dashboard refund flow (which voids the ticket QR) rather than refunding through the payment provider's dashboard out of band.
- Reply within 5 business days to a refund dispute escalated by an attendee to Orkora.

6. Content and conduct

You agree not to host events that are illegal in the jurisdiction where the event takes place. You agree not to publish content on the event page that is defamatory, infringing, deceptive, or that incites violence, hatred, or discrimination.

Orkora maintains an abuse-takedown process:

- Acknowledge receipt of a complaint within 1 business day.
- Complete review within 3 business days.
- Suspend or take down the offending event or content if the complaint is substantiated.

If we suspend or take down your event we will tell you why, give you an opportunity to respond, and (where the event continues to be live) preserve attendee data and refund obligations.

7. Data protection

For the personal data your attendees give us when registering for your event:

- **You** are the controller. You decide why the data is collected, what it is used for, and how long it is kept.

- **Orkora** is the processor. We process the data on your written instructions (those instructions are encoded in your dashboard configuration, in the Privacy Policy, and in this Agreement).

You agree to:

- Provide attendees with a privacy notice that meets the standard of the data-protection law applicable to your event (NDPR, GDPR, UK GDPR, or the equivalent).
- Honour data-subject rights requests from your attendees within the period required by applicable law.
- Notify Orkora at dpo@orkora.events within 24 hours if you become aware of a data breach affecting attendee data, and cooperate with our investigation.

Orkora will:

- Process attendance data only on your behalf for the purpose of operating the event on the platform.
- Maintain the sub-processor list in the Privacy Policy and give you 30 days' notice before changing it.
- Notify you within 72 hours if Orkora becomes aware of a breach affecting your attendees' data.

[COUNSEL NOTE: this section is our DPA-by-reference until a standalone DPA template is drafted. Per LEGAL_REVIEW_PACKET §2 we asked whether the Privacy Policy sub-processor table plus this clause is sufficient or whether we need a separate DPA the Organiser signs. Decision pending counsel.]

8. Confidentiality

Each party will keep confidential any non-public information shared by the other in the course of the relationship. This does not apply to: information that becomes publicly known through no fault of the receiving party, information already known to the receiving party before disclosure, or information disclosed pursuant to a legal obligation.

9. Term and termination

This Agreement starts when you create your Organisation and continues until either party terminates with 30 days' written notice. Either party may terminate immediately for material breach if the breach is not cured within 14 days of written notice.

On termination:

- Your access to the dashboard ends.
- Live events continue to be honoured to existing attendees through their scheduled end date.
- Attendee data is preserved per the retention schedule in the Privacy Policy.
- Outstanding refund obligations to attendees survive termination.

10. Chargebacks and risk

You acknowledge that excessive chargebacks pose a risk to Orkora's payment-provider relationships. If your chargeback rate exceeds **1% of net transactions over any rolling 30-day window** (the Visa and Mastercard "Excessive Chargeback Threshold"), Orkora may:

- Require additional KYC or business documentation.
- Hold a percentage of settled funds as a chargeback reserve for up to 180 days.
- Suspend payment processing on your Organisation.
- Terminate this Agreement for cause.

We will give you written notice and a reasonable opportunity to remediate before taking any of these steps, unless the chargeback rate or the underlying conduct is so severe that we must act immediately to protect the platform.

11. Marketing communications by Organisers

You may use Orkora's campaigns module to send email to your registered attendees about the event they registered for. You may **not** use it to send unsolicited marketing for other events or third-party offers unless the attendee opted in to that marketing at the time of registration.

Every campaign sent from Orkora includes a one-click unsubscribe link. If a recipient unsubscribes, they go into your Organisation's suppression list and Orkora will refuse to send further campaigns to them on your behalf. You are not permitted to circumvent this suppression by re-importing the email through another channel.

You agree to comply with the marketing-communications law in the jurisdiction of your attendees (CAN-SPAM in the US, CASL in Canada, GDPR Art. 13 plus PECR in the EU and UK, NDPR plus the NCC SMS guidelines in Nigeria).

12. Branding

You retain ownership of your brand assets you upload. You grant Orkora a non-exclusive licence to display your logo, name, and event images on the platform for the purpose of operating your events.

Orkora may, with your permission, list your Organisation or event on a public customer page. We will ask before doing so.

13. Indemnity

You agree to indemnify and hold harmless Orkora against any claim, loss, damage, or expense arising from:

- An event you host, including injury to attendees, refusal of entry, or non-delivery of promised content.
- Content you publish on the platform.
- Your breach of this Agreement or the Orkora Terms of Service.
- Your processing of attendee personal data outside the controller-processor framing in Section 7.

14. Limitation of liability

Orkora's total aggregate liability to you under this Agreement is subject to the cap in the Orkora Terms of Service. Nothing in this Agreement limits liability that cannot be excluded under applicable law.

15. Notices

- To Orkora: hello@orkora.events for operational matters, legal@orkora.events for legal notices.
- To you: the contact email on the Organisation's billing record.

16. Governing law and venue

This Agreement is governed by the laws of the **Federal Republic of Nigeria**. Disputes are subject to the exclusive jurisdiction of the courts of **Lagos State, Nigeria**, with the equity-and-injunction carve-out described in the Terms of Service.

17. Contact

- General: hello@orkora.events
- Billing: billing@orkora.events
- Legal: legal@orkora.events
- Security: security@orkora.events
- Data protection: dpo@orkora.events

6. Appendix A: per-org sending-domain DNS auth runbook

Organizer sending-domain authentication

When an Orkora organizer wants to send campaign emails from their own domain (e.g.

`hello@tech-summit.events` instead of the shared `no-reply@orkora.events`), the domain must be authenticated with SPF, DKIM, and DMARC. Without it, deliverability drops sharply (Gmail and Outlook downrank or quarantine unauthenticated bulk mail) and the DMARC alignment check fails outright.

This doc is the operator-and-organizer-facing runbook. The platform domain `orkora.events` itself is already authenticated; this is about the organizer's own.

Why it matters

- **Inbox placement.** Authenticated mail lands in the inbox; the rest goes to spam / promotions / quarantine.
- **Reputation isolation.** A bad send from one organizer cannot tank the shared `orkora.events` sender reputation if the organizer is sending from their own domain.
- **Brand trust.** Recipients see the organizer's own domain in the From line, not Orkora's.
- **Compliance.** CAN-SPAM and the new EU eIDAS rules increasingly prefer (and in some cases require) authenticated senders for commercial mail.

Records to publish

The organizer publishes these DNS records on their own domain. The Orkora team helps interpret if needed; we cannot publish on their behalf because we don't have access to their DNS.

Replace `<org-domain>` with the organizer's actual sending domain (e.g. `tech-summit.events`).

1. SPF (TXT, root)

```
Host: <org-domain>
Type: TXT
Value: "v=spf1 include:spf.mtasv.net ~all"
```

`spf.mtasv.net` is Postmark's SPF include. `~all` is soft-fail, which is the right setting while DMARC is in monitor mode; tighten to `-all` once DMARC is enforcing.

If the organizer already has an SPF record (common — Google Workspace or Microsoft 365 publish one), they merge the `include:spf.mtasv.net` into the existing record. They do NOT publish two SPF TXT records; many DNS validators reject that.

2. DKIM (TXT, Postmark-issued subdomain)

The organizer gives Orkora their domain. Orkora provisions a Postmark Sender Signature for that domain, which returns a DKIM record. The organizer then publishes:

```
Host: <postmark-token>._domainkey.<org-domain>
Type: TXT
Value: "k=rsa; p=<long-base64-public-key>"
```

The exact `<postmark-token>` and `<long-base64-public-key>` come from the Postmark Sender Signature provisioning step.

3. DMARC (TXT, subdomain)

Start in monitor mode:

```
Host: _dmarc.<org-domain>
Type: TXT
Value: "v=DMARC1; p=none; rua=mailto:dmarc-reports@orkora.events; pct=100; aspf=r; adkim=r"
```

After 14 days of clean monitor reports, ratchet to `p=quarantine`, then after another 14 days to `p=reject`. The `rua=` address routes aggregate reports to Orkora so we can spot misconfiguration before the organizer does.

4. Return-Path (CNAME, optional but recommended)

```
Host: pm-bounces.<org-domain>
Type: CNAME
Value: pm.mtasv.net
```

This gives Postmark a custom Return-Path under the organizer's domain, which improves DMARC alignment further and means bounce reports also use the org's domain.

Operator procedure

1. Organizer requests custom sender domain via Orkora support (Slice D wires this into a self-service flow under `/dashboard/settings/sending-domain`).
2. Orkora ops:
3. Adds the organizer's domain to Postmark as a Sender Signature
4. Retrieves the SPF + DKIM + DMARC values
5. Sends them to the organizer with this runbook attached
6. Organizer publishes the records on their DNS.
7. Organizer notifies Orkora when published.
8. Orkora ops:
9. Verifies via `dig` (commands below)
10. Confirms Postmark Sender Signature status flips to "Verified"

11. Sets `OrganizationDomain` row in DB (Slice D schema) with `verified=true` so the campaigns composer allows From addresses on this domain
12. Organizer creates campaigns from `<anything>@<their-domain>` and sends.

Verification commands

Run these against the organizer's domain before flipping `verified=true`.

```
# SPF
dig TXT <org-domain> +short | grep spf1

# DKIM (the postmark-token is in the Postmark Sender Signature page)
dig TXT <postmark-token>._domainkey.<org-domain> +short | grep p=

# DMARC
dig TXT _dmarc.<org-domain> +short

# End-to-end test: send a real email and read the headers
# Look for: spf=pass smtp.mailfrom=<org-domain>
# Look for: dkim=pass header.d=<org-domain>
# Look for: dmarc=pass policy.dmarc=none
```

Free third-party checks: mxtoolbox.com/spf, dmarcian.com, mail-tester.com.

What if the organizer can't / won't?

Default behaviour: campaigns send from the shared `hello@orkora.events` sender. Deliverability is good (the shared domain is fully authenticated) but the From line reads "Orkora," which some organizers don't want. We always honour their explicit opt-out preference if they pick the shared sender.

Touchpoint with `CAMPAIGNS_SPEC.md`

Slice A of the campaigns module accepts any `fromEmail` and trusts the organizer to use an authenticated domain. Slice D adds:

- `organization_sending_domains` table (id, organizationId, domain, postmarkTokenId, verified, lastVerifiedAt)
- Self-service domain-verification wizard in the dashboard
- A guard in `campaigns.service.create()` that rejects a `fromEmail` whose domain is not verified for that org

Until Slice D ships, the campaigns composer's From-email field is trusted; operators should manually verify that organizers are using domains they actually control before approving large sends.